Controls & Gap Analysis

Final Audit Report and Findings Package

Assessment focus
Access governance, PII/PHI protection, role transfers, quarterly certification, and control effectiveness

Prepared by: Keyonia Taylor
Applied GRC Portfolio Project

Executive Summary

The audit identified interconnected weaknesses in role-transfer reconciliation, quarterly access-review performance, and certification oversight within a fictional Medicare Advantage environment. A prior-role Member Data permission remained active after an employee transferred to an IT Administrator role, then passed through the March quarterly review without correction. Testing found four detectable access mismatches; two were identified and two were approved unchanged. The evidence supports a combined failure: unclear ownership of transfer reconciliation, inconsistent reviewer execution, a review interface that did not compare expected and actual access, and an oversight process that certified completion without clearly defined quality validation. No evidence established employee misuse or required independent review of every record by the certifier. Immediate priorities are an independent re-review, correction of confirmed access gaps, automated mismatch detection, documented exception approvals, and clearly defined certification procedures.

Overall assessment: Control improvement required

Findings at a Glance

No.	Finding	Risk	Condition	Recommendation
1	**Role-transfer reconciliation**	**High**	Old-role Member Data access remained after transfer to IT Administrator.	Require end-to-end transfer reconciliation with named ownership and evidence of completion.
2	**Quarterly review effectiveness**	**High**	Four detectable mismatches existed; two were missed and approved unchanged.	Conduct an independent re-review; retrain and quality-test reviewers; document evidence for decisions.
3	**Review workflow design**	**High**	Expected access and actual access were not displayed together; approvals required no evidence or comments.	Automate role-to-access comparison and block unsupported approvals until resolved or excepted.
4	**Certification oversight**	**Moderate**	Oversight was assigned, but required quality-validation steps were not defined.	Define risk-based quality review, escalation, evidence retention, and authority to reject weak reviews.

Audit Objective and Scope

Assess whether user permissions align with current job responsibilities; role changes remove obsolete access; periodic reviews identify inappropriate permissions; decisions are evidence-supported; and certification provides reliable oversight.

Scope included employee roles, expected and actual access, transfer and provisioning records, review activity, exception handling, reviewer training and workload, and certification responsibilities.

Finding 1: Role-transfer reconciliation

Risk rating: High

Condition

Old-role Member Data access remained after transfer to IT Administrator.

Root cause

Ownership for confirming removal, provisioning, and final reconciliation was unclear.

Risk / impact

Residual access may expose PII/PHI beyond current business need.

Recommendation

Require end-to-end transfer reconciliation with named ownership and evidence of completion.

Finding 2: Quarterly review effectiveness

Risk rating: High

Condition

Four detectable mismatches existed; two were missed and approved unchanged.

Root cause

The reviewer did not consistently compare actual access with documented role requirements.

Risk / impact

Excessive and insufficient access may remain undetected after certification.

Recommendation

Conduct an independent re-review; retrain and quality-test reviewers; document evidence for decisions.

Finding 3: Review workflow design

Risk rating: High

Condition

Expected access and actual access were not displayed together; approvals required no evidence or comments.

Root cause

The process relied heavily on manual recognition, memory, and judgment.

Risk / impact

A mismatch can pass when it does not appear unusual to the reviewer.

Recommendation

Automate role-to-access comparison and block unsupported approvals until resolved or excepted.

Finding 4: Certification oversight

> **Risk rating: Moderate**

Condition

Oversight was assigned, but required quality-validation steps were not defined.

Root cause

Certification emphasized completion without defined sampling, high-risk review, or exception validation.

Risk / impact

A completed review may be certified even when the primary review is unreliable.

Recommendation

Define risk-based quality review, escalation, evidence retention, and authority to reject weak reviews.

Individual Accountability Assessment

Individual	Assessment	Basis
James	No misconduct substantiated	Member Data access originated from a legitimate prior role; no evidence showed James caused the residual permission.
Elena Brooks	Reviewer-performance issue substantiated	Elena relied on assumptions and did not consistently verify access against current-role requirements; process design and workload contributed.
Robert Chen	Individual failure not substantiated	The evidence did not show Robert was required to re-review every record; oversight design remained insufficiently defined.

Future-State Control Workflow

1. Establish current employee role

2. Retrieve approved role-access baseline

3. Retrieve actual assigned permissions

4. Automatically compare expected and actual access

5. Generate exceptions for excessive, insufficient, privileged, or unsupported access

6. Investigate and remediate or document a time-bound exception

7. Obtain independent approval for sensitive or high-risk exceptions

8. Perform defined certifier quality review

9. Certify only after unresolved issues are addressed or escalated

Overall Conclusion

The access issue survived multiple control layers: obsolete access was not removed during the role transfer, the quarterly review did not detect the mismatch, no exception was generated, and certification did not provide a defined quality check capable of detecting the failed review. Sustainable remediation therefore requires both improved execution and redesigned controls.